10 Controlling access with authorization

This chapter covers

- Enabling authorization services within a Razor Pages application
- Using roles and claims to authorize endpoints
- Creating authorization policies from requirements and handlers
- Authorizing access to resources

In the last chapter, you learned how to identify your users by asking them to authenticate themselves. Once authenticated, the user is no longer anonymous; they have an identity, which we can use to restrict access to various parts of the application. This process is known as *authorization*, and it is vital for securing parts of your application against users who should not have access to them.

Even the simplest dynamic web application is likely to include an area where the owner maintains the content—an admin area. That will need securing against unauthorized access, unless you want random users to start posting their own content, or worse: defacing or removing your existing content. More complex applications can require complex access policies where different users have different levels of authority over parts of the application. For example, you might allow a select number of users to add to the range of vacation locations offered by your website but further restrict who can manage prices. Customers will be able to book vacations and see details of their own orders, but only administrators can see details of all orders. Super admins might be the only people who can change parts of an order.